HEALTH PRIVACY TO HIPAA AND BEYOND

HIPAA, Your Data, Data sets, and other related legalish things

De-identification and re-identification risk, Washington's consumer health data law, and the states following its lead

Wendy Knox Everette · HACKERS - November 2026

HIPAA de-identification methods

HIPAA Privacy Rule · 45 CFR 164.514(b): two paths

Expert Determination

§ 164.514(b)(1)

- A qualified expert applies statistical or scientific principles
- Risk is very small that the anticipated recipient could identify anyone
- Documented, and tied to a specific recipient and context

Safe Harbor

§ 164.514(b)(2)

- Remove 18 types of identifiers, for the individual and relatives, employers and household members
- No actual knowledge that what remains could identify anyone

Either way, de-identified data is no longer PHI: it leaves HIPAA entirely and can be used, shared or sold

Safe Harbor: the 18 identifiers

1 Names	7 Social Security numbers	13 Device identifiers and serial numbers
2 Geographic units smaller than a state*	8 Medical record numbers	14 URLs
3 All date elements except year*	9 Health plan beneficiary numbers	15 IP addresses
4 Telephone numbers	10 Account numbers	16 Biometric identifiers, including finger and voice prints
5 Fax numbers	11 Certificate and license numbers	17 Full-face photos and comparable images
6 Email addresses	12 Vehicle identifiers, including license plates	18 Any other unique identifying number, characteristic or code

And: the covered entity may not have “actual knowledge that the information could be used alone or in combination with other information to identify an individual who is a subject of the information.”

***The first 3 ZIP digits may stay if that area has more than 20,000 people; ages over 89 become a single 90+ group**

Re-identification: what the research shows

87%

of Americans are unique on 5-digit ZIP, birth date and sex (Sweeney, 2000)

4 points

of time and location singled out 95% of people in a mobile phone dataset (de Montjoye et al., 2013)

99.98%

of Americans correctly re-identified using 15 demographic attributes (Rocher et al., 2019)

1997 · MASSACHUSETTS

Governor William Weld’s hospital records found by linking “anonymized” state employee health data to Cambridge voter rolls

2016 · AUSTRALIA

De-identified Medicare and pharmaceutical claims for 10% of the population re-identified by researchers about six weeks after release

Why de-identified health data still carries risk

Safe Harbor is a big blunt change without nuance

Rare diagnoses, procedure codes, timestamps and free text can survive and single people out.

Data points can get linked

Consumer health, location and ad-tech data, the MHMDA world, supply the matching keys.

Hashing is not de-identification

A hashed email or device ID is still a persistent identifier; the FTC has said so plainly.

Context outside the dataset

An expert determination is only a one off for that one dataset roughly in isolation, and safe harbor is a sledgehammer

CONTROLS

Contract against re-identification and onward sharing · minimize fields and granularity · re-review on new uses · log and limit who can link datasets

WASHINGTON STATE

Consumer health data vs PHI

The My Health My Data Act and where it meets HIPAA

MHMDA at a glance

April 2023

Signed into law (HB 1155), codified at RCW 19.373

March 31, 2024

In effect; small businesses followed June 30, 2024

No thresholds

Any entity doing business in or targeting Washington

What counts as consumer health data

- Conditions, symptoms, treatments and medications
- Reproductive, sexual and gender-affirming care data
- Biometric and genetic data
- Location suggesting someone sought health care
- Inferences drawn from non-health data like purchases or searches

Core obligations

- A standalone consumer health data privacy policy
- Opt-in consent to collect, and separate consent to share
- Signed, expiring authorization before any sale
- Rights to access, delete and withdraw consent
- No geofencing within 2,000 ft of health care facilities

Enforcement: a violation is a per se Consumer Protection Act violation, so the Attorney General *and* private plaintiffs can sue

Where HIPAA ends and MHMDA begins

The HIPAA exemption follows the data, not the organization.

Data scenario	HIPAA	MHMDA
Clinical records and claims at a covered entity	PHI, so HIPAA applies	Exempt
PHI a business associate handles for a covered entity	PHI, so HIPAA applies	Exempt
Tracking pixels on a hospital's public, unauthenticated pages	Often outside HIPAA after AHA v. Becerra (2024)	Likely consumer health data
A covered entity's non-PHI data: marketing lists, events, consumer apps	Not PHI	Covered if it reveals health status
Direct-to-consumer health, fitness and cycle-tracking apps; wearables	Generally not covered	Consumer health data
Retail, ad-tech and location data that implies health (OTC buys, clinic visits)	Not covered	Consumer health data

Also exempt: 42 CFR Part 2 records, WA UHCIA data, HIPAA-deidentified data, regulated research data, GLBA, FCRA and FERPA data

HIPAA and MHMDA, side by side

	HIPAA	MHMDA
Who's covered	Covered entities and business associates	Any entity doing business in or targeting Washington, of any size
What data	Protected health information	Consumer health data, including inferences and location
Default rule	Treatment, payment and operations allowed without authorization	Opt-in consent to collect; separate consent to share
Selling data	Prohibited without authorization	Signed authorization that expires after one year
Individual rights	Access, amendment, accounting of disclosures; no general right to delete	Access (incl. who received the data), deletion reaching processors, third parties and backups
Enforcement	HHS OCR and state AGs; no private right of action	Attorney General plus a private right of action under the CPA

THE INSURER CONTEXT

Can consumer health data ever become PHI?

Some insurers ask members to track and submit their steps, or require internet-connected scales

Health plan programs: same data, two regimes

A step count is PHI or consumer health data depending on who holds the copy, and why.

Who holds the data, for what purpose	HIPAA	MHMDA
Health plan collecting steps or activity for a member rewards program	PHI; the plan is a covered entity	Exempt
Employer wellness program offered as part of the group health plan	PHI; employer access only as plan sponsor	Exempt
Wellness vendor, device maker or PBM handling data for the plan	Business associate; PHI	Exempt for that copy
The same vendor using the data under its own consumer app terms	Outside the BAA	Consumer health data
Employer wellness program run directly, outside the health plan	Not PHI	Unclear: employment-context exclusion

Sources: HHS OCR, “HIPAA Privacy and Security and Workplace Wellness Programs” (2015); RCW 19.373 exemptions

Example: connected scales for GLP-1 coverage

Member

Weighs in on a plan-required, internet-connected scale to start or keep a GLP-1 prescription covered

→

Scale or program vendor

Business associate for what it does for the plan; **MHMDA for its own consumer uses**

→

Health plan or PBM

Readings support a coverage decision: PHI under HIPAA, exempt from MHMDA

Questions to ask

BAA scope: what may the vendor do with readings beyond the plan's purpose?

Secondary use: are readings reused for product work, marketing or de-identified data sales?

Second copy: does the member also accept the vendor's app terms? That copy needs MHMDA consent and deletion.

Minimum necessary: does the plan receive only what the coverage decision needs?

What this means for a HIPAA-regulated organization

Map data, not departments

Classify each flow as PHI, consumer health data or both; the same team can hold all three.

Treat trackers as the top risk

Pixels and SDKs on public pages and apps sit exactly in the gap between the two laws.

Paper vendors twice

BAAs cover PHI; MHMDA processor contracts cover everything else health-related.

Build consent and deletion plumbing

Separate consents, sale authorizations and deletion that reaches third parties and backups.

LITIGATION SIGNALS

First MHMDA class action against Amazon (Feb 2025, ad SDK location data) · a 2025 suit against a cannabis retailer · the WA AG's first Data Privacy Report (Aug 2026)

Other states regulating consumer health data

State	Law and status	What stands out	Enforcement
Nevada	SB 370, in effect March 31, 2024	Closest MHMDA mirror: consent, written authorization to sell, geofence ban	AG only
Connecticut	CTDPA health provisions, July 1, 2023; amended 2025 and 2026	Consent to sell; geofence ban; health rules apply regardless of size thresholds	AG only
Maryland	MODPA, in effect October 1, 2025	Bans selling sensitive data outright; collect only what is strictly necessary	AG only
Vermont	S.71, signed June 2026; effective Jan 1, 2028	Consent to sell; 1,850-ft geofence ban; no volume thresholds	AG only
New York	NYHIPA (S9269): passed June 2026, awaiting governor	Broadest scope yet, reaching health inferences; prior version vetoed Dec 2025	AG, up to $15K per violation

Washington stands alone in pairing no-threshold scope with a private right of action. Also watch Virginia's reproductive health data rule and Michigan's 2026 copycat bill (HB 5769).

Status as of early November 2026